

Thesis Threat Model Report — Scenario 1

LLM-Integrated Authentication Assistant System | Multi-Framework Audited Threat Dataset

106 RAW FINDINGS	12 VALIDATED THREATS	94 DUPLICATES EXCLUDED	100.0% GROUNDING RATE	11.3% THREAT PRECISION
---------------------	-------------------------	---------------------------	--------------------------	---------------------------

ID	Element	STRIDE	Framework Mappings	Threat Description & Evidence	Mitigation Strategy	CVSS	Stage
T1.01	P1 — Web Frontend Interface DF16: Chatbot Answer -> P1	Tampering	ATT&CK: T1059.007: JavaScript OWASP: A03:2021 – Injection (XSS) ATLAS: AML.T0054: LLM Output Manipulation LLM Top10: LLM02: Insecure Output Handling LINDDUN: Disclosure of Information ML Sec: ML06: AI Supply Chain & Output Integrity	Cross-Site Scripting (XSS) via unescaped rendering of processed AI chatbot answers (DF16), allowing attacker-injected script payloads to execute in victim browser context. Evidence: P1 receives DF16 Chatbot Answer and displays it to EE1. Untrusted LLM output rendered without contextual escaping creates an execution vector in the browser.	Enforce contextual HTML entity encoding and DOMPurify sanitization before rendering chatbot responses; implement a strict Content Security Policy (CSP).	AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N8.1	Implementation
T1.02	P2 — Authentication Service DF5: Login Request / DF6: Credential Submission	Spoofing	ATT&CK: T1110.001: Password Guessing / T1110.003: Credential Stuffing OWASP: A07:2021 – Identification and Authentication Failures ATLAS: – LLM Top10: – LINDDUN: Identifiability ML Sec: –	Automated brute-force attacks and credential stuffing against the login endpoint to impersonate legitimate user accounts. Evidence: EE1 submits login credentials (DF5) forwarded via P1 to P2 (DF6). Credential verification entry point creates an authentication attack surface.	Implement adaptive rate limiting on login submission endpoints, progressive delays, account lockout policies, and breached credential checks.	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N9.1	Design
T1.03	P2 — Authentication Service DF4: Registration Result / DF8: Authentication Verification Result	Information Disclosure	ATT&CK: T1589.002: Gather Victim Identity Information – Email Addresses OWASP: A07:2021 – Identification and Authentication Failures ATLAS: – LLM Top10: – LINDDUN: Detectability & Identifiability ML Sec: –	User enumeration via differential error responses or execution timing discrepancies during credential verification. Evidence: P2 determines login/registration success or failure (DF4/DF8) and returns status to P1. Distinct error messages or unpadded timing expose user presence.	Return uniform generic authentication error messages ('Invalid username or password') and use constant-time verification logic.	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N5.3	Implementation
T1.04	P2 — Authentication Service DF6: Credential Submission	Denial of Service	ATT&CK: T1499.002: Endpoint Denial of Service – Service Exhaustion OWASP: A05:2021 – Security Misconfiguration ATLAS: – LLM Top10: – LINDDUN: Unawareness / Non-compliance ML Sec: –	High-cost password hashing denial of service: attacker floods login submission endpoints with requests, exhausting P2 CPU resources on password hash calculations. Evidence: DF6 delivers credentials to P2, which executes cryptographic password hashing routines. Unthrottled submissions exhaust server processing capacity.	Apply per-IP and per-subnet ingress rate limits and asynchronous hashing queues with concurrency limits.	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H7.5	Implementation
T1.05	P3 — Session Management Module DF10: Session Token	Spoofing	ATT&CK: T1539: Steal Web Session Cookie / T1552: Unsecured Credentials OWASP: A07:2021 – Identification and Authentication Failures ATLAS: – LLM Top10: – LINDDUN: Linkability & Identifiability	Session token predictability or weak entropy in token generation allows an attacker to forge valid session tokens and hijack authenticated user sessions. Evidence: P3 generates session tokens (DF10) returned to P1. Predictable tokens undermine session authentication authority.	Generate session tokens using cryptographically secure pseudo-random number generators (CSPRNG) with at least 128 bits of entropy.	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N9.1	Design

ID	Element	STRIDE	Framework Mappings	Threat Description & Evidence	Mitigation Strategy	CVSS	Stage
			ML Sec: –				
T1.06	P3 — Session Management Module DF9: Session Creation Request / DF10: Session Token	Elevation of Privilege	ATT&CK: T1539: Steal Web Session Cookie OWASP: A07:2021 – Identification and Authentication Failures ATLAS: – LLM Top10: – LINDDUN: Linkability ML Sec: –	Session fixation vulnerability: pre-authentication session identifier is preserved post-login, allowing an attacker to fix a known session ID and access the authenticated account. Evidence: P3 manages session state creation upon DF9 request. Preserving existing session tokens across authentication boundaries enables fixation.	Regenerate and issue a new session token upon successful authentication, immediately invalidating old pre-login identifiers.	8.1 AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:~H/A:N	Implementation
T1.07	P4 — AI Chatbot Component DF11: Chatbot Question	Tampering	ATT&CK: T1059: Command and Scripting Interpreter OWASP: A03:2021 – Injection ATLAS: AML.T0051: LLM Prompt Injection LLM Top10: LLM01: Prompt Injection LINDDUN: Non-compliance ML Sec: ML01: Adversarial Robustness & Input Manipulation	Direct prompt injection via user-supplied chatbot queries (DF11) manipulating system prompt context to elicit unauthorized guidance or system disclosures. Evidence: P4 receives untrusted free-text input (DF11) crossing TB1 and forwards it to P5. Prompt injection directly targets P4/P5 processing.	Apply structural prompt isolation (delimiters), input sanitization, and intent classification filters on incoming queries.	6.5 AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N	Design
T1.08	DF12 — Prompt Request DF12: Prompt Request -> P5 / DF13: Prompt and Context Data -> EE2	Information Disclosure	ATT&CK: T1552: Unsecured Credentials OWASP: A01:2021 – Broken Access Control ATLAS: AML.T0024: LLM Data Leakage LLM Top10: LLM06: Sensitive Information Disclosure LINDDUN: Disclosure of Information ML Sec: ML09: Model Inversion / Training Data Leakage	Sensitive authentication secret leakage: prompt assembly logic inadvertently includes session tokens (DF10) or user credentials in the prompt sent across TB2 to the External LLM Provider. Evidence: Architecture explicitly mandates: 'session tokens and authentication secrets must not be provided to the LLM'. Flaws in P4/P5 context construction violate this constraint.	Enforce strict schema-level data minimization and automated secret filtering on P4/P5 prompt builders before transmitting DF13.	6.5 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:~N/A:N	Design
T1.09	P5 — LLM Integration Service DF13: Prompt and Context Data	Information Disclosure	ATT&CK: T1552.001: Credentials in Files / Logs OWASP: A05:2021 – Security Misconfiguration ATLAS: – LLM Top10: – LINDDUN: Disclosure of Information ML Sec: –	Server-side LLM provider API credentials are leaked through unredacted application logs, stack traces, or client-accessible error messages. Evidence: P5 holds server-side credentials to communicate with EE2 across TB2. Explicit requirement: API key is server-side secret material.	Store API keys in dedicated secret stores and redact authorization headers from all application logs and diagnostics.	7.5 AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:~N/A:N	Implementation
T1.10	P5 — LLM Integration Service DF13: Prompt and Context Data / DF14: Generated Response	Denial of Service	ATT&CK: T1499: Endpoint Denial of Service OWASP: A05:2021 – Security Misconfiguration ATLAS: AML.T0029: Denial of ML Service LLM Top10: LLM04: Model Denial of Service LINDDUN: Unawareness ML Sec: ML04: Resource Depletion	Exhaustion of upstream LLM API rate limits or connection pools due to rapid prompt submissions, causing denial of service for all AI chatbot features. Evidence: P5 communicates synchronously with EE2 across TB2. Third-party rate limits or latency spikes exhaust worker threads.	Implement circuit breakers, token bucket rate limiters, request timeouts, and graceful degradation responses.	7.5 AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:~N/A:H	Implementation
T1.11	DS1 — User Database DF3: Account Creation / DF7: Credential Verification Query	Information Disclosure	ATT&CK: T1190: Exploit Public-Facing Application (SQL Injection) OWASP: A03:2021 – Injection ATLAS: – LLM Top10: – LINDDUN: Disclosure of Information ML Sec: –	SQL/Query injection in credential verification routines (DF7) leads to unauthorized exfiltration of stored user password hashes and account records. Evidence: DS1 stores usernames, password hashes, and authentication records accessed by P2 across TB3.	Enforce strictly parameterized database queries and strong password hashing (Argon2id/bcrypt) with unique salts.	7.5 AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:~N/A:N	Implementation

ID	Element	STRIDE	Framework Mappings	Threat Description & Evidence	Mitigation Strategy	CVSS	Stage
T1.12	DS3 — Knowledge Base / Context Repository SF3: Approved Context Query / SF4: Approved Context Data	Tampering	ATT&CK: T1565.001: Stored Data Manipulation OWASP: A08:2021 – Software and Data Integrity Failures ATLAS: AML.T0048: Insecure Output Handling / Poisoning LLM Top10: LLM08: Vector and Context Poisoning LINDDUN: Non-compliance ML Sec: ML02: Data Poisoning	Knowledge Base poisoning: unauthorized modification of stored authentication documentation leads the AI assistant to provide deceptive or compromised authentication instructions. Evidence: DS3 supplies approved contextual guidance queried by P4/P5 across TB3. Tampered context directly influences generated guidance.	Enforce strict write authorization, version control, and cryptographic integrity verification on all documentation records.	4.9 AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N	Design